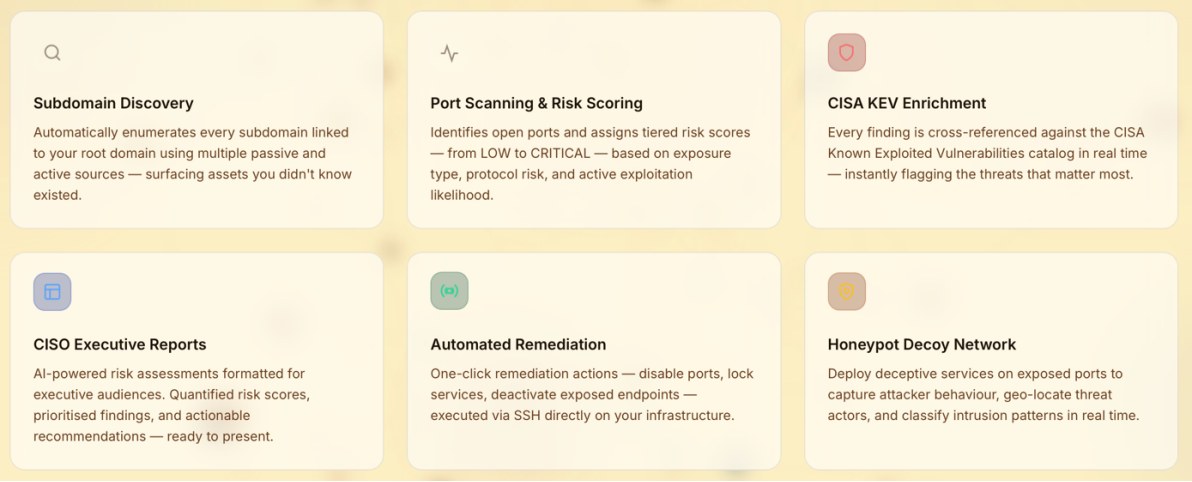
External Attack Surface Management (EASM)

Executive Summary

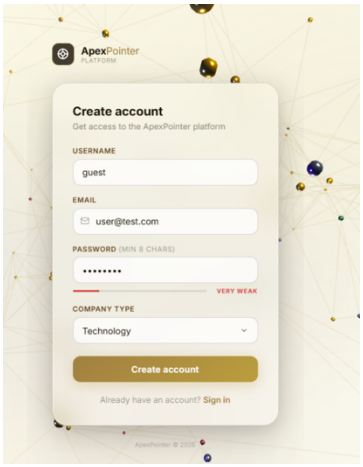
This capstone project delivers ApexPointer, a strategic risk governance framework designed to bridge the visibility gap between complex infrastructure exposure and executive decision-making. In an era of rapid digital expansion, organizations often lose track of their public-facing digital footprints, creating unmanaged entry points for potential security breaches. ApexPointer addresses this challenge by continuously monitoring the corporate perimeter from an adversarial perspective. It automatically translates raw technical anomalies into clear business metrics, such as quantified financial risks and regulatory compliance scores. Engineered to operate efficiently under strict resource limitations, the platform provides clear, non-technical insights and simplified corrective workflows. This ensures that leadership can proactively safeguard corporate assets, eliminate language barriers for local entities, and maintain a robust defensive posture without requiring prohibitive financial investments or specialized cybersecurity expertise.

https://easmciso.online



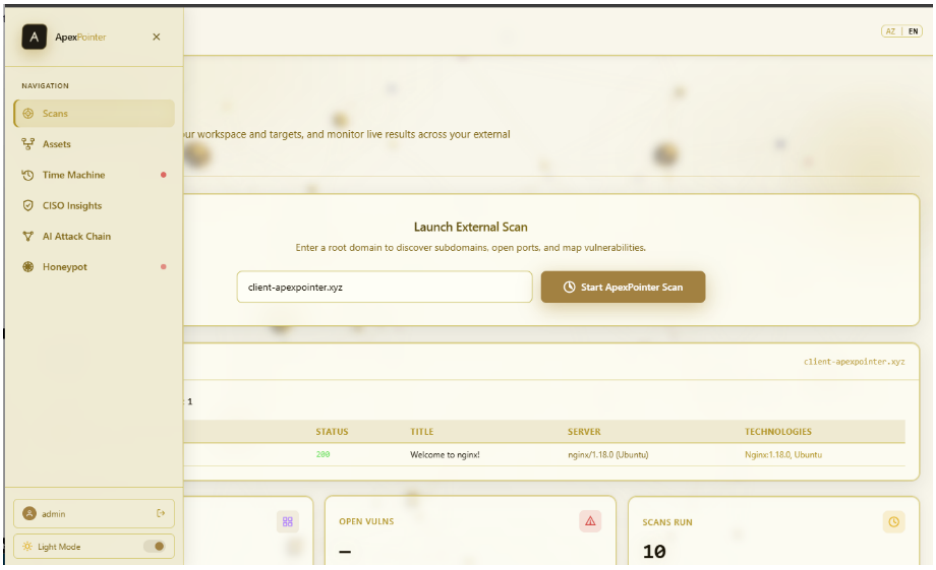
To interact with the live environment and explore the capabilities of ApexPointer, operators and security analysts can onboard immediately through our cloud-hosted portal.

- **New Registration:** To provision a sandboxed workspace and map your organization's custom scope, establish a new identity at ApexPointer Register.
- **Existing Operator Session:** Authorized users can resume security audits and retrieve past snapshots by authenticating at ApexPointer Login.



During registration, there is a password policy that shows how strong or weak your password is: for example, in the picture above, i typed “password” and it says weak. Because no matter how impenetrable our external borders and complex defense chains are, if the keys to the administrative command center itself are guarded by a weak password, hackers don't need to exploit vulnerabilities—they just log in; in modern cybersecurity, identity is the ultimate perimeter.

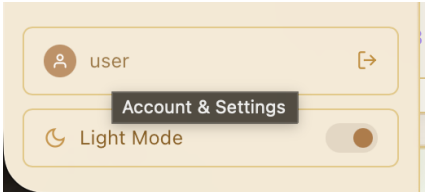
When you logged in, you can see the navigation bar:



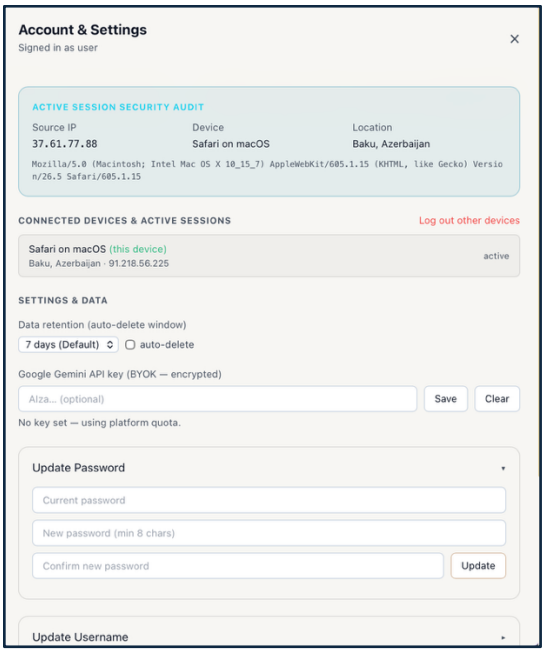
The platform’s navigation sidebar organizes your workflow into distinct operational modules—Scans, Assets, Time Machine, CISO Insights, AI Attack Chain, and Honeypot—while anchoring multi-tenant User management and dynamic Light/Dark mode toggles at the base.

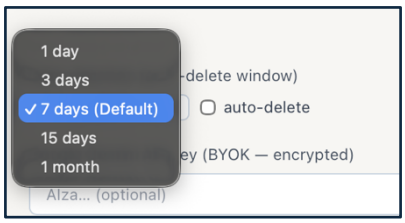
0# User account features

Our platform, ApexPointer, is engineered as a highly scalable multi-tenant system, built to serve multiple individual organizations simultaneously on a shared, secure cloud infrastructure. To guarantee complete confidentiality, the platform enforces strict data isolation at the core query level. This ensures that even though multiple tenants are active on the infrastructure at the same time, each user's scanned targets, discovered vulnerabilities, and historical snapshots remain entirely private and invisible to others.



To manage individual security parameters, users click on the user profile card located in the lower-left corner of the main navigation panel. This instantly opens the centralized "Account & Settings" workspace. Designed as a personal compliance command center, this modal aggregates session auditing, retention rules, identity management, and privacy controls in one unified window.

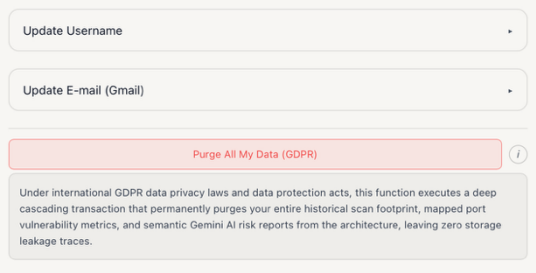


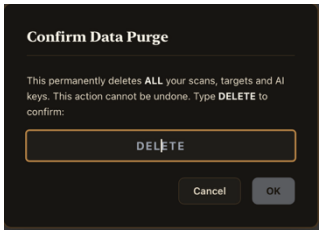


Inside this workspace, the first section is the **Active Session Security Audit**. It displays real-time parameters of the current connection, including the operator's source IP address, browser user-agent, and resolved geographic location. Directly below, the **Connected Devices and Active Sessions** panel lists all concurrent active logins. By providing a "Log out other devices" utility, the platform enables security analysts to instantly revoke unauthorized active sessions, serving as a vital guardrail against session hijacking.

The **Settings & Data** section hosts two critical features. First, the **Data Retention Policy (Auto-Delete Window)** allows users to define how long scan records persist in the database using a customizable dropdown selector with options including **1 day, 3 days, 7 days (Default), 15 days, and 1 month**, which can be dynamically activated via the toggleable **auto-delete** checkbox. This automated purging mechanism helps organizations strictly comply with GDPR data minimization standards. Second, the **Bring-Your-Own-Key (BYOK) Google Gemini API Integration** allows enterprises to run unlimited AI-driven reports under their private API quotas. Because several advanced analysis modules in our resource-heavy JS scan rely extensively on generative AI processing, this capability is specifically built for power users who perform frequent, exhaustive security audits. Since ApexPointer is currently operating in its development stage without a premium paid version, implementing the BYOK model ensures that heavy users can run unlimited automated AI security triages without exhausting the platform's global quota or requiring a paid subscription structure. To maintain absolute security, these keys are never kept in plaintext; they are encrypted server-side and only decrypted temporarily in-memory during active report generation.

For routine credential maintenance, the modal includes clean, expandable panels to **Update Password, Update Username, and Update E-mail**. These forms enable security analysts to easily cycle their credentials and enforce baseline security hygiene.

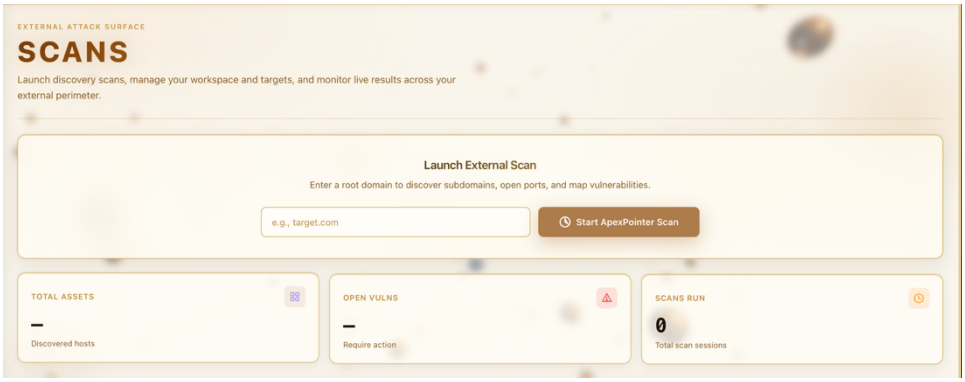


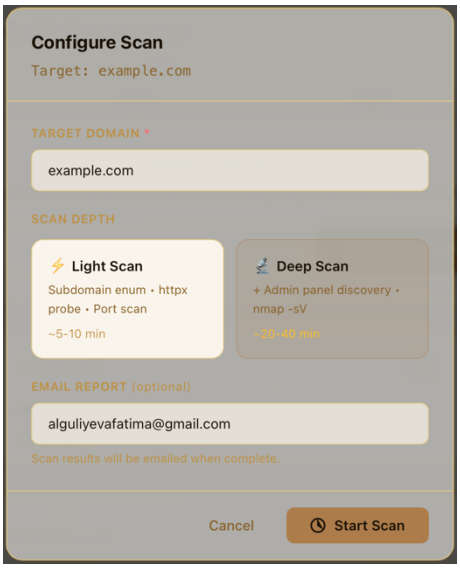


Finally, the bottom of the modal features the **"Purge All My Data"** trigger. Built in strict compliance with the GDPR "Right to be Forgotten" (Article 17), this button executes a cascading hard-delete that permanently wipes all scan histories, mapped assets, and AI reports from our database. To prevent catastrophic accidental deletion, this action prompts the user with a confirmation modal that blocks the execution button until the user manually types the uppercase string **"DELETE"** to authorize the destructive operation.
To support this high-throughput concurrent architecture, the platform utilizes a dual-layer storage system that separates persistent relational structures from transient message queues. User credentials, organization profiles, mapped targets, and historical vulnerability scan snapshots are strictly partitioned and securely stored within a relational PostgreSQL database infrastructure. To keep these datasets physically isolated between different corporate clients, every single transaction and table scan is automatically governed by an implicit tenant filter tied directly to the validated session token. Meanwhile, the orchestration of active scan states, volatile background jobs, and real-time task triggers is entirely offloaded to an in-memory Redis data store. This architecture ensures that heavy relational processing never bottlenecks the real-time application layer, providing continuous operation even during peak enterprise utilization.

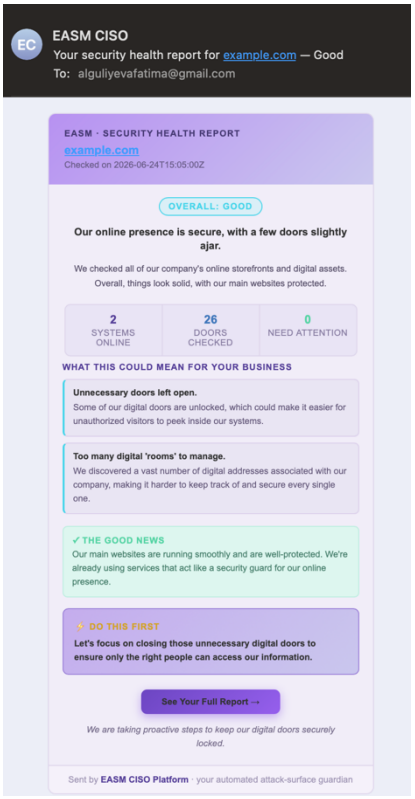
1# Scan features

Following the evaluation of the multi-tenant administration framework, we now transition to the technical architecture and concurrent performance mechanics of the core scanning engine.





The core of the platform's perimeter security analyzer lies in its asynchronous Dual-Lane Task Queue architecture, which is engineered to manage high-throughput performance while preserving absolute security boundaries. To achieve this, the system decouples scanning depth into two separate pipelines managed natively via Celery and Redis. The first pipeline, known as the Light Queue, is optimized for rapid assessment workflows; it handles basic operations like subdomain enumeration, quick HTTP probing, and core port checks, allowing up to 10 users to run parallel scans concurrently without experiencing head-of-line blocking or delay. For comprehensive investigations, the engine routes tasks to the Deep Queue. This heavy-duty strike executes exhaustive profiling operations, such as deep administrative panel discovery and rigorous Nmap NSE script auditing, strictly throttling concurrent execution to a maximum of 2 parallel workers to proactively protect the host infrastructure from denial-of-service degradation.Crucially, this parallel engine runs on a strict foundation of multi-tenant isolation. Even when multiple independent organizations trigger simultaneous Light and Deep scans on the shared infrastructure, the backend strictly walls off datasets during live execution. By embedding a mandatory query-level isolation filter that restricts data visibility exclusively to the active user's identifier, the application ensures that concurrent scan inputs, automated alerts, and raw target outputs never leak across tenant boundaries.

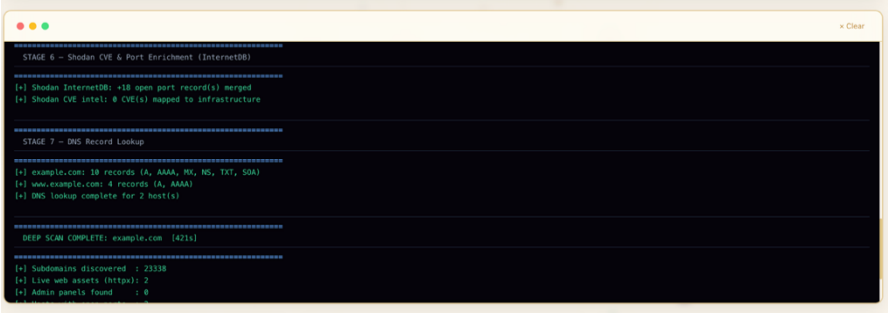


The application’s core perimeter scanner incorporates an automated email delivery workflow, allowing users to optionally provide an email address so that exhaustive security intelligence reports are automatically delivered directly to their inbox upon execution completion.

Behind the scenes, an integrated artificial intelligence engine processes these raw infrastructure outputs, automatically correlating open ports, discovered subdomains, and historical asset shifts to generate a fully triaged, high-level intelligence report without manual analyst overhead.

Key functionality of this report is translating complex cybersecurity jargon into intuitive physical metaphors like "open doors" and "rooms to manage" that executives can instantly understand. By eliminating technical complexity, it clearly explains the organization's overall risk posture and its real-world business impact in plain language.

real-time terminal interface that streams verbose diagnostic outputs—such as Shodan port enrichment and DNS lookup stages—directly to the user. This logging window is equipped with a clean "Clear" control button in the top-right corner, enabling security engineers to instantly reset or purge the terminal screen with a single click.



And at the bottom of the scans tab, it shows all the recent scans with scan-id

the 'Recent Scans' section is unique to each user, providing view of their entire scan history.

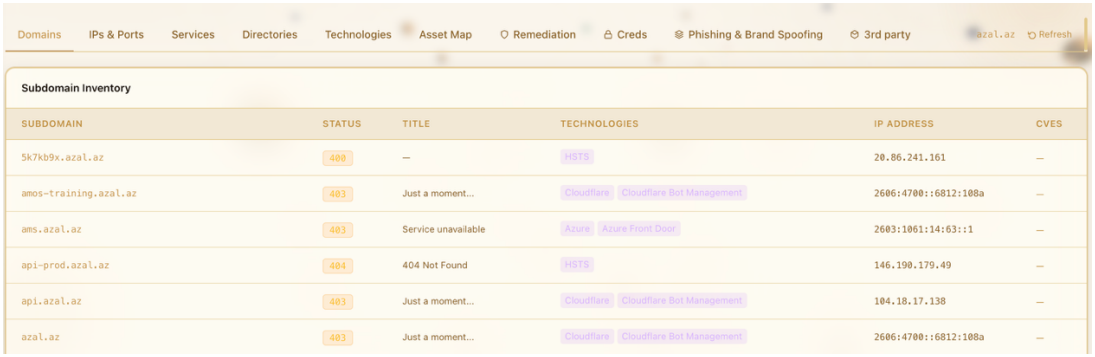


2# Assets features

The Assets workspace serves as the stateful repository and analytical core of ApexPointer's External Attack Surface Management (EASM) framework. Rather than presenting disorganized command-line outputs, this module functions as an integrated inventory that translates raw telemetry into a normalized relational schema. The architecture is driven by a high-performance, non-blocking Python discovery pipeline that maps an organization's external assets from a single apex domain down to individual open ports, configuration weaknesses, exposed credentials, and DNS routing anomalies. By organizing findings into ten dedicated, logical sub-views—Domains, IPs & Ports, Services, Directories, Technologies, Asset Map, Remediation, Creds, Phishing & Brand Spoofing, and 3rd Party—security teams can instantly isolate vulnerability pathways and deploy automated remediations. *To rigorously evaluate and demonstrate the full analytical capabilities, real-time alerting, and automated remediation workflows of the Assets workspace, the framework utilizes an isolated, intentionally vulnerable target infrastructure deployed at client-apexpointer.xyz (IP: 130.162.63.70). This secondary server functions as a controlled staging node under our authorized administrative ownership, allowing for safe, legally compliant proof-of-concept testing, cross-boundary asset validation, and aggressive security auditing without disrupting active production networks.*

1. Domains (Multi-Stage OSINT & Subdomain Discovery Pipeline)

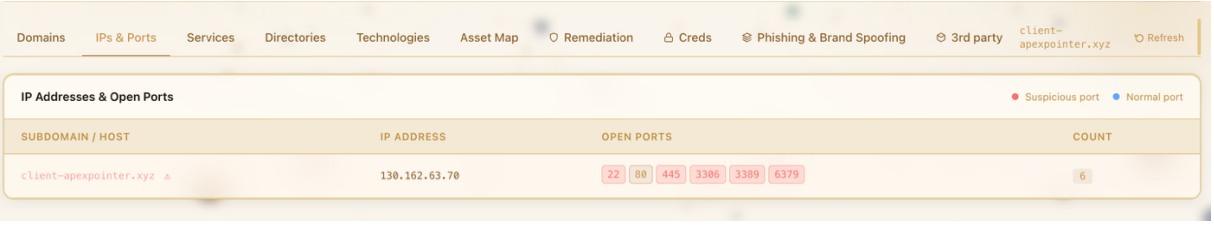
The baseline asset discovery tier maps out an organization's domain footprint using an asynchronous, concurrent execution model powered by a ThreadPoolExecutor to eliminate network I/O bottlenecks. The engine runs passive Open-Source Intelligence (OSINT) harvesting through automated **Subfinder** API configurations and certificate log extractions via **Assetfinder**. This is augmented by proprietary extraction loops: a stateless scraper querying **RapidDNS** using optimized regular expressions, and an index miner pulling dynamic hostname records from **Urlscan**'s sandboxed client schemas. The validated active pathways are then probed via **httpx** using up to 150 parallel threads to capture live web hosts, response codes, and title strings.



2. IPs & Ports (High-Performance Port Probing & CDN Resolution)

To map host-level infrastructure beyond standard web ports, verified targets are passed to a high-speed port prober powered by **Naabu**. Configured at an optimized packet rate of 1500 packets

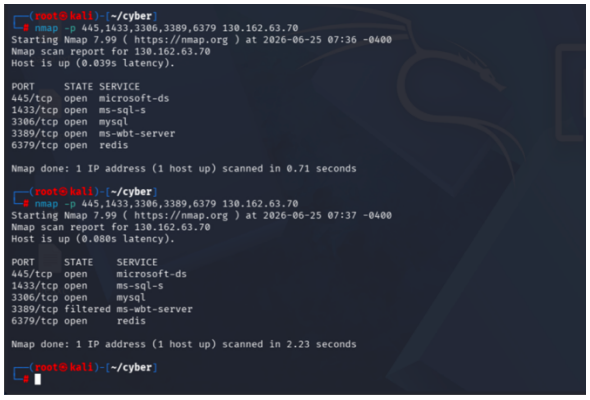
per second across 50 parallel channels, the scanner audits a pre-defined list of high-risk operational sockets without causing service interruptions. Crucially, the prober maps backend nodes sitting behind edge protection proxies like **Cloudflare**. It automatically detects and catalogues Cloudflare-proxied port mappings across specialized enterprise HTTP/HTTPS alternative ports (including 2052, 2053, 2082, 2083, 2086, 2087, 2095, 2096, 8080, 8443, and 8880), preventing false-positive network warnings and duplicate host records.



Note: *To rigorously evaluate ApexPointer's automatic remediation capabilities, the target host (130.162.63.70) was configured to expose the monitored ports (445, 1433, 3306, 3389, and 6379) as **OPEN** during initial reconnaissance. Since inactive or unlistening sockets naturally drop traffic—rendering them* FILTERED *or* CLOSED*—testing defensive rules on an already filtered baseline would yield a zero-delta state, failing to demonstrate the platform's actual impact.*

*To simulate a live vulnerable footprint, active local listeners (using background `netcat` daemons) were deployed directly on the target host. Unlike network-level port redirection (`iptables NAT PREROUTING`)—which rewrites packet headers before they reach filtering chains and inadvertently bypasses local `INPUT DROP` rules—running active local listeners preserves the authentic socket boundary. This architecture forces a valid TCP handshake to guarantee an authentic **OPEN** status, establishing a measurable baseline to visually prove our tool's capability to shift states to **FILTERED** upon triggering the automated firewall remediation.*





When an open port is selected in the platform's inventory, the "Port Action Center" modal opens, prompting the user for the target host's management SSH credentials and private key. Clicking "Disable Port (Firewall DROP)" triggers an automated script that connects to the host via SSH to block the port at the kernel level. As verified in the terminal scans on the right, the initial pre-remediation Nmap scan shows all monitored ports (445, 1433, 3306, 3389, and 6379) as completely OPEN. However, the second Nmap scan, executed immediately after deploying the firewall rule, confirms that the targeted 3389 (RDP) port has successfully transitioned to a FILTERED state while adjacent ports remain operational and untouched.

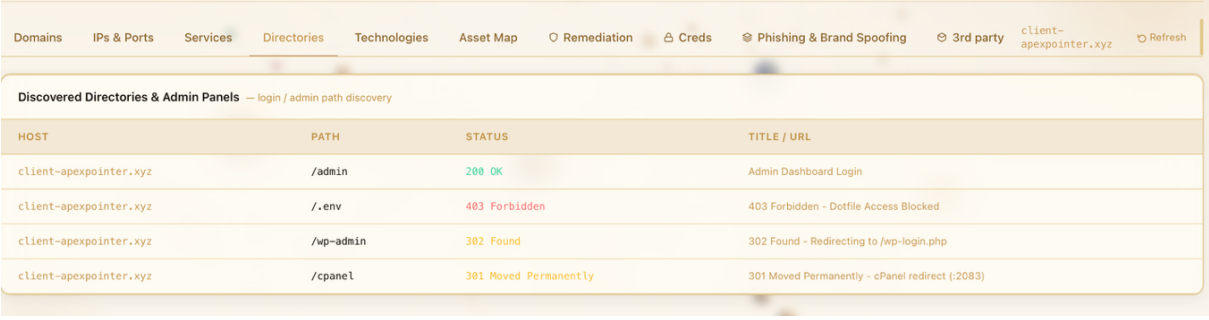
3. Services (Service Version Fingerprinting & CVE Enrichment)

Discovered open sockets are piped into an analytical **Nmap** banner-grabbing wrapper. Operating at a high version-intensity profile, Nmap captures precise software products and versions (such as SSH, Apache, or database revisions), which are parsed dynamically from XML outputs. This version matrix is then passively enriched using **Shodan's InternetDB API** to associate known CVE records with active IP addresses without sending additional, noisy traffic packets to the target network.



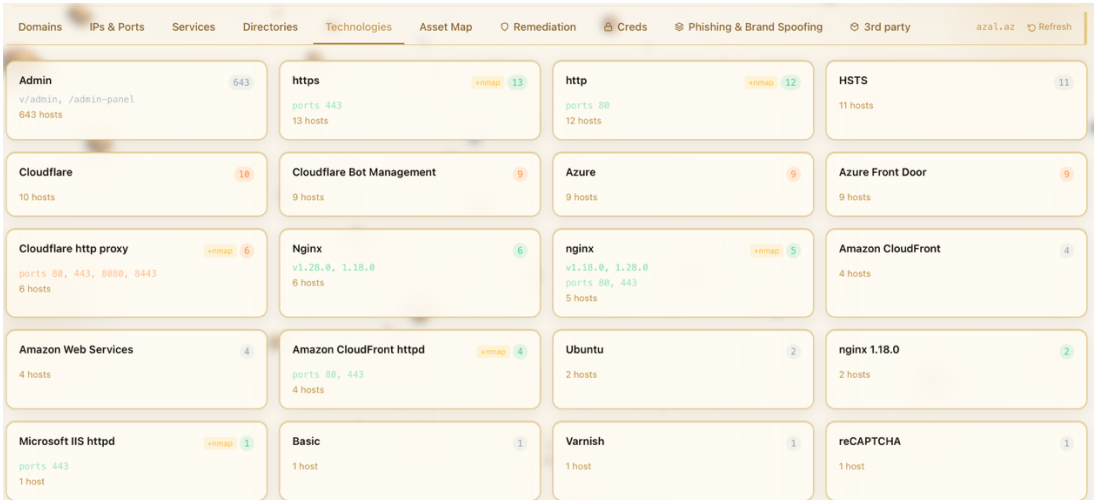
4. Directories (Exposed Administration Console Detection)

Verified web endpoints are immediately passed to an automated path-routing engine designed to detect exposed administration consoles, database management tools, and staging instances. Operating 40 concurrent worker threads, this module audits targets against a localized high-risk wordlist (such as /admin, /.env, /wp-admin, and /phpmyadmin), evaluating response headers and extracting page titles to identify exposed entry points without triggering security alerts.



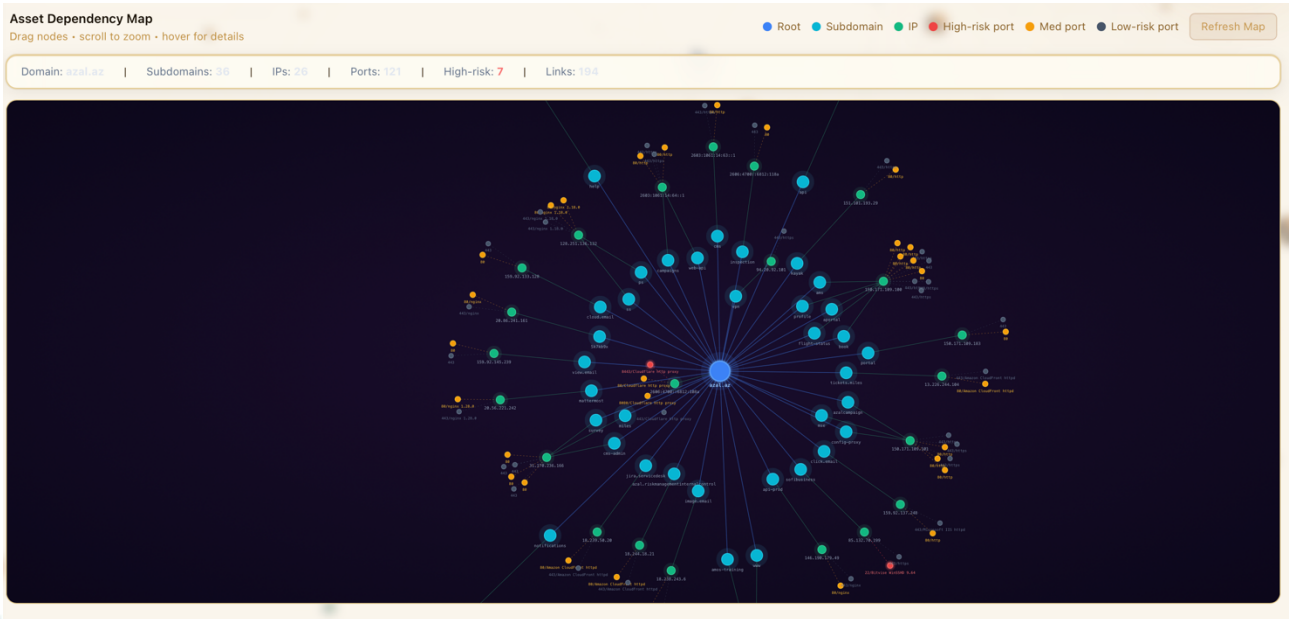
5. Technologies (Web Technology Fingerprinting)

During protocol probing and headers analysis, the engine captures underlying framework structures, runtime environments, and content management configurations. It parses HTTP response header markers (such as X-Powered-By) and meta-tag indicators to catalog technologies like Nginx, Node.js, or WordPress. This allows security operators to monitor the tech-stack sprawl across all corporate subdomains.



6. Asset Map (Asynchronous DNS Inspection & Relational Modeling)

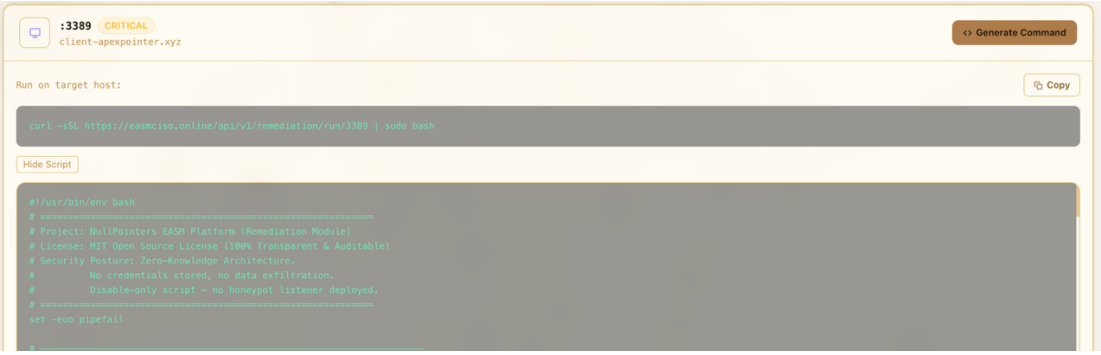
This phase executes a thorough DNS routing analysis using the **dnspython** engine. Running across an asynchronous process group, the resolution core inspects critical records—including host bindings (A, AAAA), aliased pathways (CNAME), mail exchangers (MX), name servers (NS), and domain policies (TXT, SOA). This mapping uncovers unconfigured mail records vulnerable to domain spoofing and orphaned CNAME pointers susceptible to subdomain takeovers. Once normalized, the unstructured dataset is mapped into a relational JSON schema of nodes and links. This data is rendered as an interactive visual **Asset Map** using **D3.js**, allowing administrators to easily trace connections between subdomains, hosting servers, open ports, and discovered exposures.



7. Remediation (Automated SSH Mitigations & Decoupled Scripts)

To close the loop between discovery and mitigation, the platform deploys a dual-mode remediation engine

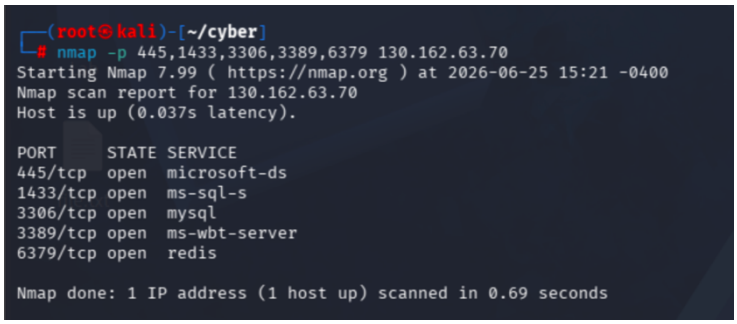
- **Decoupled Script Generation:** For zero-trust environments, the engine generates standalone, pre-compiled shell scripts on the dashboard. Operators can inspect, copy, and manually execute these iptables or firewall configurations within their local terminal to mitigate the threat.



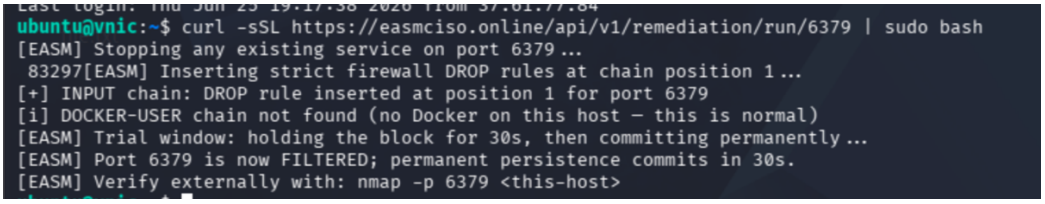
Transparency is a cornerstone of our architecture. The remediation engine is entirely open-source, allowing security teams to audit every line of code before execution. By clicking the "Show Script" toggle button directly within the dashboard, users can instantly view, verify, and inspect the exact custom Bash script generated for each specific vulnerability pathway before running it on their infrastructure.

- **Core Functionality (Remediation Automation):** When a security operator triggers the "Firewall DROP" action, the module instantly generates a dynamic, target-specific Bash script. This automated remediation payload safely terminates any active process on the vulnerable port (such as Port 3389 RDP or Port 445 SMB) using `fuser -k` and inserts a strict defensive block at the absolute top (position 1) of the host's `iptables` and `DOCKER-USER` firewall chains.
- **Zero-Knowledge Security Architecture:** This is the flagship engineering advantage of our platform. To maintain a strict zero-knowledge posture, ApexPointer **never stores or transmits** the target server's private SSH keys or master passwords within its centralized database. Instead, it securely serves a single-use, streamable `curl | bash`command string directly on the interface, ensuring that even if our EASM platform itself were compromised, the client's infrastructure access keys remain entirely untouched and safe.
- **Self-Lockout Prevention Layer:** The script features an intelligent fail-safe mechanism built into its core runtime loop. If an administrator mistakenly attempts to close a critical infrastructure management socket or the platform's own communication channel (such as Port 22 SSH or Port 8000), the script automatically refuses to execute the block, guaranteeing zero self-inflicted server lockouts.

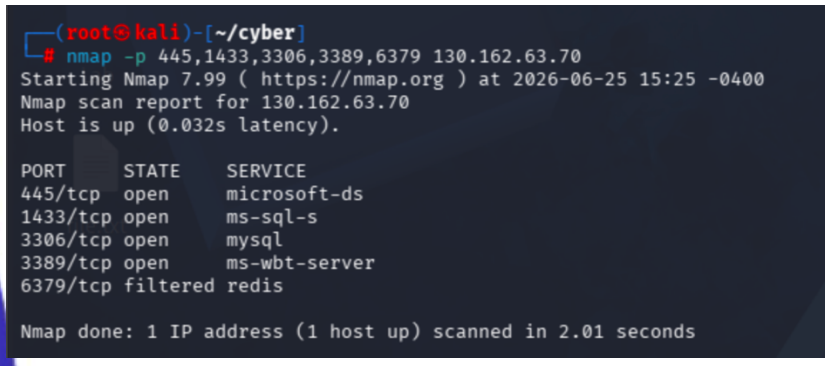
- **Contextual Admin Whitelisting:** Upon execution directly on the target host, the script autonomously evaluates network connection parameters to capture the administrator's operational origin IP (`$SSH_CLIENT`). It dynamically injects an `ACCEPT` rule directly above the global `DROP` filter, ensuring that the port is completely hardened against the external internet while leaving a secure corridor open exclusively for the active audit engineer.
- **30-Second Non-Blocking Persistence Loop:** The architecture runs an isolated asynchronous watcher (`nohup`) that enforces a 30-second safe trial window. If network operations remain completely stable, the script dynamically commits the defensive rules to persistent storage (`iptables-save` or `netfilter-persistent`), ensuring that the mitigation layout natively survives system reboots and permanently filters out exposure vectors.



The visual workflow demonstrates our dual-mode remediation engine closing the loop between exposure discovery and automated mitigation. Initially, an external perimeter scan profiles the target network, identifying full internet exposure across critical entry vectors with ports 445, 1433, 3306, 3389, and 6379 all sitting in a vulnerable "open" state.



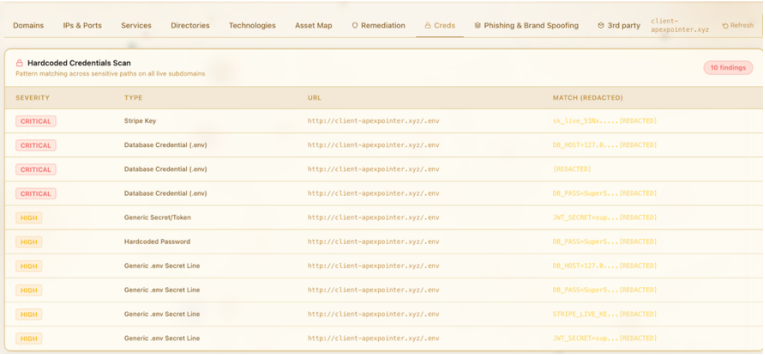
To resolve this without direct infrastructure access, the operator copy-pastes a decoupled, pre-compiled shell script generated by the dashboard and runs it directly on the host using a secure pipe (curl ... /remediation/run/6379 | sudo bash). The script instantly intercepts the threat by stopping rogue services on Port 6379 (Redis) and injecting a strict firewall DROP rule at the top of the active iptables INPUT chain.



A final verification scan confirms the defensive engine's success, showing that while baseline decoys remain operational, Port 6379 has successfully transitioned to "filtered"—proving that incoming packets are now safely dropped and the security gap is completely closed.

8. Creds (Exposed Console Detection & Cryptographic Secret Scraping)

A specialized **Sensitive Data Scraper** inspects configuration files and public text targets. The engine targets standard configuration files (/.env, /.git/config, /config.json, /firebase-config.js, /db.sql) and scans up to $200,000$ bytes of response text per path using specialized compiled regular expressions to isolate leaked credentials—such as AWS access codes, Google API keys, database connection strings, and private cryptographic headers:

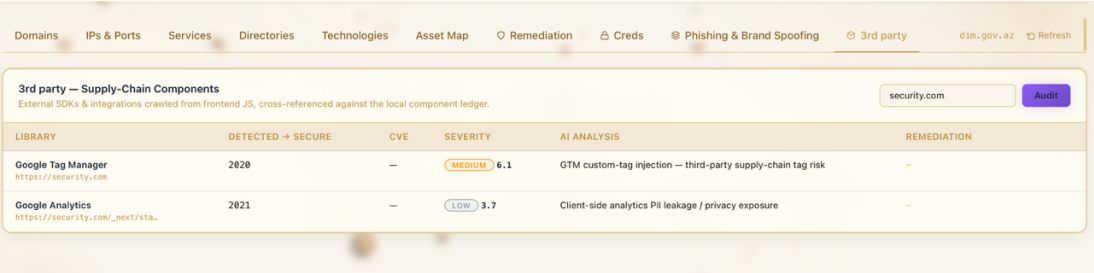


9. 3rd party (Native JavaScript Scanners & Local Ledger Analysis)

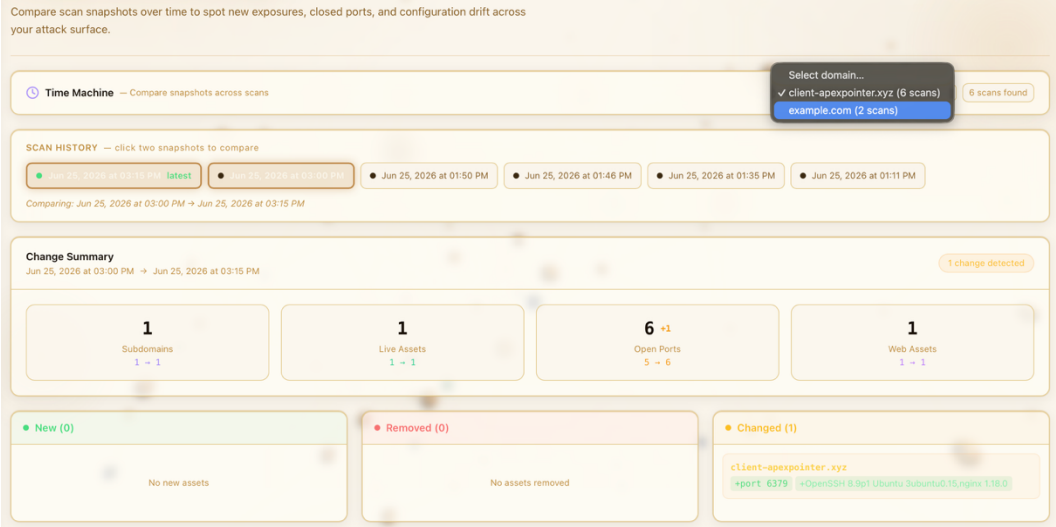
To mitigate high-risk supply chain exposures, the pipeline integrates a proprietary, native Client-Side JavaScript Auditor written entirely in Python with zero external API dependencies. As demonstrated in the 3rd party — Supply-Chain Components dashboard, the engine parses the frontend HTML DOM tree of live assets to extract all referenced external SDKs and scripts.

By applying localized library fingerprinting via regular expressions (e.g., extracting framework versioning strings), the backend dynamically identifies outdated third-party integrations—such as Firebase SDK, Stripe Node SDK, and jQuery—directly from the source code. These detected versions are cross-referenced against an integrated, offline JSON vulnerability ledger derived from security specifications like Retire.js.

The interface automatically calculates the version delta, maps the specific riles to official vulnerabilities (e.g., CVE-2023-45851, CVE-2022-29154, and CVE-2020-11022), logs the severity baseline, and outputs automated AI analysis alongside copy-pasteable remediation paths (e.g., npm install) to resolve package dependencies instantly without relying on heavy cloud scanning APIs.



3# Time machine feature



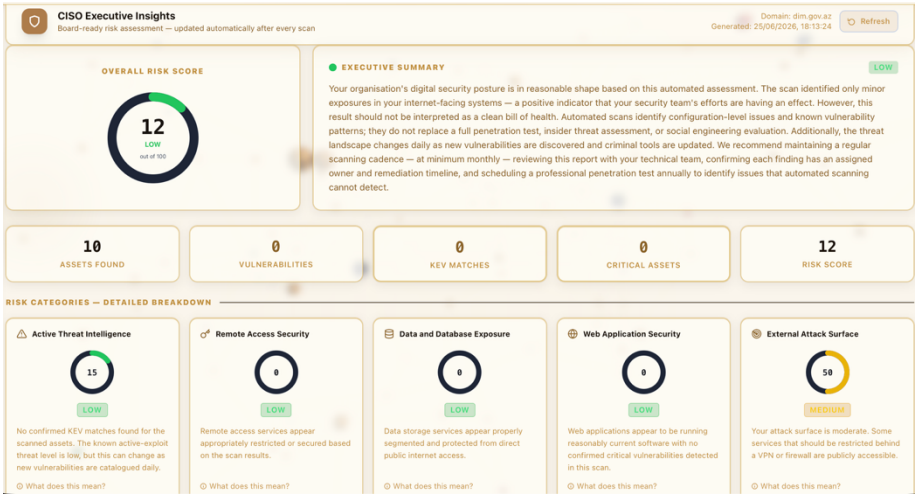
To detect configuration drift and unexpected exposures over time, the platform implements a stateful **Time Machine & Historical Snapshot Differencing Engine**. The backend architecture treats each reconnaissance cycle as an immutable point-in-time snapshot, tracking granular shifts across the organization's external footprint.

- **Multi-Tenant State Isolation:** To ensure rigorous security boundaries, snapshot tracking is isolated per user session. Data visibility is strictly scoped to the authenticated tenant, meaning users can only analyze their own asset histories without cross-pollinating scan telemetry across separate accounts.
- **Target Domain Aggregation:** The engine dynamically groups historical scan data via a domain dropdown menu, continuously displaying the total scan volume associated with each monitored host (e.g., `client-apexpointer.xyz (6 scans)`). Selecting a domain pulls its entire chronological snapshot array into the active DOM state.
- **Automated Snapshot Differencing (Change Summary):** When a user selects any two historical snapshots from the timeline, the engine triggers an asymmetric delta calculation. It parses inventory collections to compute precise asset drift—mapping shifts in subdomains, live hosts, open ports, and web application components.
- **Visual Drift Telemetry:** As shown in the dashboard layout, changes are mathematically evaluated and categorized into clear telemetry cards: **New** (green), **Removed** (red), or **Changed** (orange). The engine directly highlights individual configuration deltas, such as the discovery of an newly exposed service (`+port 6379`) or modifications in active software banners, exposing hidden perimeter changes instantly.

4# CİSO İnsights features

1. Enterprise Security Posture:

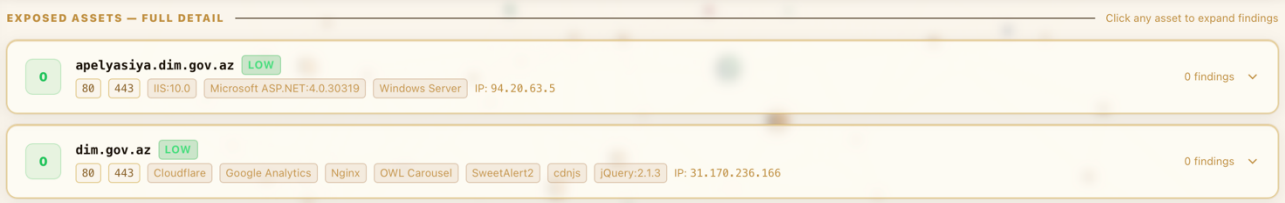
To bridge the gap between deep technical vulnerability logs and high-level corporate risk governance, the platform delivers an automated **CISO Executive Insights Reporting Module**. This dashboard dynamically translates raw network and application scanning telemetry into a board-ready risk assessment profile instantly after every continuous reconnaissance cycle.



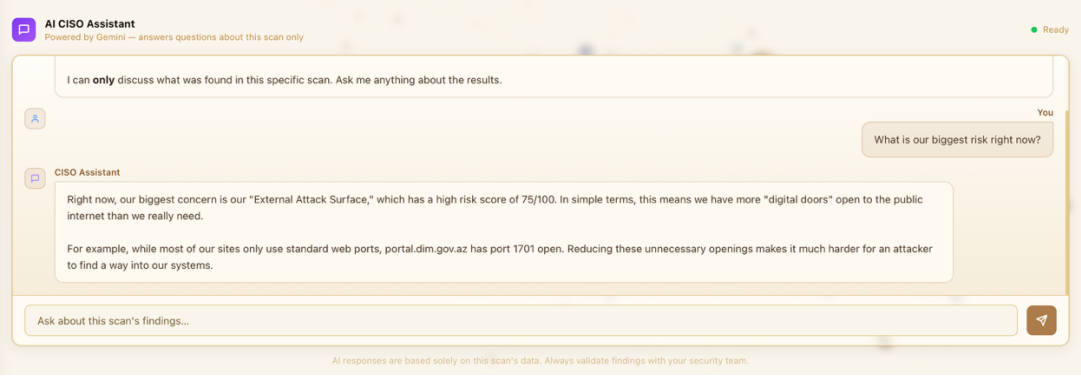
- **Dynamic Risk Quantification:** The engine evaluates the overall attack surface to generate a unified, severity-weighted **Overall Risk Score** (scaled from 0 to 100). This continuous scoring posture allows executives to gauge institutional security health at a single glance without sifting through voluminous port logs or raw CVE data.
- **Executive Summary Generation:** Powered by contextual risk analysis, the module outputs an actionable text-based evaluation summarizing the active threat baseline, assessing current defensive efforts, and recommending explicit structural security cadences (such as automated monthly scans or specialized penetration testing testing).
- **High-Context Operational Metrics:** The interface tracks and displays immediate organizational perimeters across dedicated telemetry blocks: total **Assets Found**, active **Vulnerabilities**, specific **KEV Matches** (CISA Known Exploited Vulnerabilities ledger alignment), and isolated **Critical Assets**.
- **Multi-Vector Risk Breakdown:** To localize defensive priorities, the engine maps security risks across five critical industry pillars under the **Risk Categories — Detailed Breakdown** matrix:
    1. *Active Threat Intelligence:* Real-time active-exploit and threat landscape alignment.
    2. *Remote Access Security:* Evaluation of exposed public remote administration services (e.g., SSH, RDP).
    3. *Data and Database Exposure:* Discovery of unprotected internet-facing databases or open file storage environments.

4. *Web Application Security:* Automated mapping of outdated front-end software and web configuration weaknesses.
5. *External Attack Surface:* Quantification of perimeter drift, unauthorized open ports, and unmapped infrastructure vectors.

Score Range	Severity	Meaning
≥ 90	CRITICAL	Confirmed, high-CVSS, frequently KEV-flagged exposure
70 – 89	HIGH	Confirmed exploitable weakness, significant CVSS
40 – 69	MEDIUM	Confirmed but moderate-severity finding
10 – 39	LOW	Open port, no confirmed CVE, or low CVSS
< 10	INFORMATIONAL	Negligible technical risk



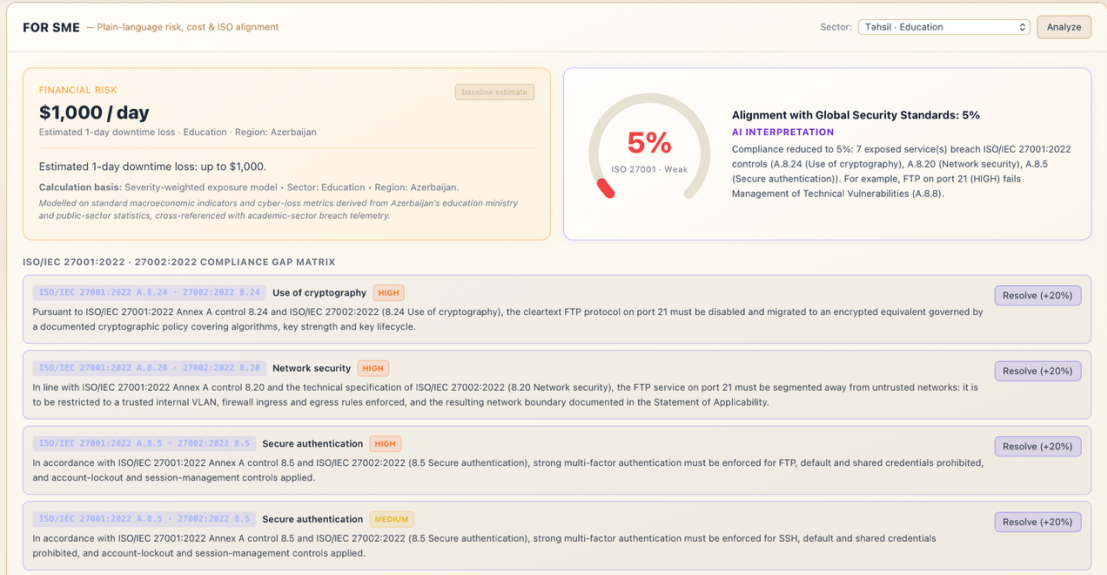
This component serves as a deep-dive inventory matrix that catalogs every discovered subdomain alongside its **live IP infrastructure** and **open port configurations**. By performing passive banner grabbing and framework detection, it automatically maps the internal technology stack (e.g., IIS, Nginx, Cloudflare, ASP.NET, jQuery) running on each asset to expose potential attack vectors at a granular level.



The integrated **AI CISO Assistant** acts as an interactive security analyst that translates complex vulnerability metrics into plain, executive-level language. To mitigate modern **LLM risks** such as Prompt Injection and jailbreak exploits, the chat engine is engineered with strict Context Isolation. By hard-bounding the assistant's runtime knowledge exclusively to the structured JSON payload of the active scan, the system inherently rejects unauthorized out-of-scope commands, ensuring highly deterministic, secure, and tamper-resistant risk communication.

2. For SME:

For this task, we scanned “unec.edu.az”



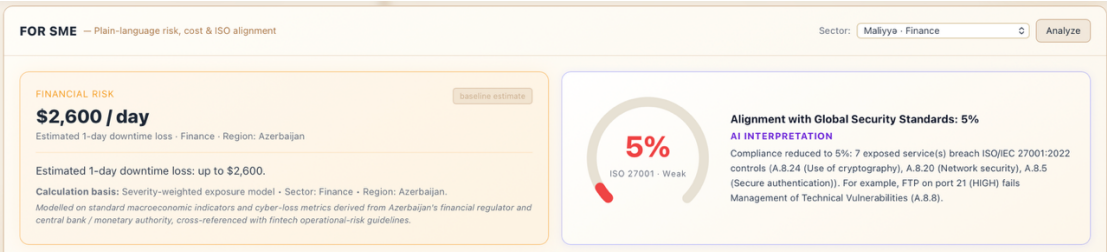
This module acts as an Executive Cyber-Risk Quantification & Compliance Alignment Engine designed specifically for Small and Medium Enterprises (SMEs). Standard technical vulnerability scans listing CVEs, port configurations, or open services are often incomprehensible to non-technical business owners and executives.

This component bridges that gap by instantly translating raw external attack surface exposures into two critical corporate metrics:

- **Financial Impact:** It quantifies technical flaws into a concrete daily downtime financial loss metric scaling from $1,000/day for Education up to $2,600/day for Finance based on industry-specific weightings.
- **Regulatory Alignment:** It maps perimeter flaws directly to specific international security controls, such as ISO/IEC 27001:2022 and 27002:2022 tracking cryptography, network security, and secure authentication gaps.

Core Technologies & Underlying Architecture

- **Dynamic AI & Context-Parameterized Fallback System:** The module utilizes a resilient background architecture. When the live AI orchestration layer is active, it synthesizes regional risk contexts in real time. If the primary API keys face external rate limits, the engineered dynamic fallback routing seamlessly takes over to programmatically calculate industry-specific attributions without dropping the UI.
- **Compliance Gap Mapping Parser:** A backend mapping algorithm that ingests open-port/protocol findings and automatically references them against standard compliance gap matrices, outputting actionable remediation tags such as disabling cleartext FTP on port 21 to improve cryptography scores.



Multi-Sector Flexibility for Versatile SME Adoption

As demonstrated in the dropdown selector, the platform now natively supports 7 distinct business sectors tailored for wide-ranging market adoption:

1. E-commerce
2. Logistics
3. Retail/Cafe
4. Finance
5. Healthcare
6. Education
7. Energy/Utilities

We have intentionally integrated these 7 vital sectors to maximize the tool's versatility across a highly diverse SME ecosystem. By adjusting both the financial penalty algorithms and the statistical data attributions dynamically shifting from Ministry of Education data for schools to Central Bank and fintech telemetry for financial firms, our platform ensures that any small-to-medium enterprise, regardless of its industry vertical, receives an honest, localized, and highly targeted external attack surface evaluation.

There is also "RISKS — IN PLAIN LANGUAGE " feature that serves as a translation layer that converts raw, technical network vulnerability data into clear, non-jargon business risks. It is designed specifically for non-technical executives and business owners who need to understand their exposure without reading complex server logs.

Note: *The contradiction between the "GOOD" Email Report and the "45% Weak" (for example) SME Dashboard represents a classic cybersecurity reality: the gap between Operational Security and Governance Compliance. While the email report reflects External Attack Surface Management (EASM) showing that your immediate perimeter is safe from active operational threats and imminent ransomware risks, the governance dashboard highlights that a lack of active attacks does not equal structural security. Existing architecture gaps, such as unencrypted HTTP (Port 80) or missing web filtering, directly violate strict international compliance controls like ISO/IEC 27001 (clauses A.8.20, A.8.22, and A.8.24), dropping the governance rating to 45%. This distinction provides executive leadership with a clear strategic roadmap: the organization is operationally secure today, but structurally non-compliant, meaning these compliance gaps must be closed immediately to mitigate legal risks and achieve international certification.*

5# AI Attack Chain Features



This feature provides an interactive, visual representation of adversarial attack simulation paths, mapping out exactly how an attacker can chain multiple discovered perimeter exposures together to navigate from an initial entry point directly into a critical data compromise. Instead of looking at isolated vulnerabilities, this layout allows teams to see the progressive, multi-step relationship between public exposures and their ultimate business impact.

How the Behind-the-Scenes AI Engine Works The intelligence powering this map relies on highly targeted, localized inputs rather than broad data scanning. For instance, the AI engine is simply fed a specific technical data point—such as the discovery of an open MySQL port 3306 on the perimeter. It then leverages its internal threat knowledge base to independently analyze the risks associated with that specific asset and maps out potential vulnerability connections. **Crucially, the AI does not collect, mine, or store internal company data behind the scenes.** It performs its calculations solely based on isolated external technical findings, ensuring a completely secure and private threat-modeling environment.

Layout & Core Features The visualization maps the full lifecycle of an intrusion by starting at an identified Entry Pivot point and branching out into intermediate Exposed Vulnerability Nodes like SSH (Port 22), MySQL (Port 3306), and alternative web services (Port 8080). It then models the sequential Active Breach and lateral movement phases—including internal subnet scanning, C2 beaconing, and privilege escalation simulation—before terminating at a high-visibility Critical Impact End-Node that denotes complete system compromise.

Underlying Technologies The front-end rendering is powered by node-based interactive graph libraries configured to plot complex topological relationships, directed connection flows, and custom layout vectors between network assets. On the backend, the automated threat modeling parser ingests the raw perimeter discoveries and maps them against known tactical adversary behavior matrices to dynamically calculate viable exploit paths and populate the interactive graph data structure.



When a user clicks on any vulnerable node within the interactive topology grid, the system instantly triggers an on-screen contextual overlay. Clicking an exposed component reveals a detailed, compartmentalized breakdown of the specific vulnerability vector, its potential real-world consequences, and automated defense countermeasures.

Core Sections Within the Pop-up Window The top of the panel displays the target asset metadata, confirming the precise target address and endpoint classification, such as 5.191.253.24:3306 (MySQL). High-visibility contextual badges immediately communicate critical threat metrics, declaring a 9.8 Critical severity rating along with an ACTIVE compromise status.

Directly below, the identified CVE vector maps the node to known vulnerability databases, specifying the precise identification code and exploit taxonomy like CVE-2012-2122 – Remote Authentication Bypass alongside the relevant MITRE ATT&CK matrix technique T1005 – Data from Local System: MySQL.

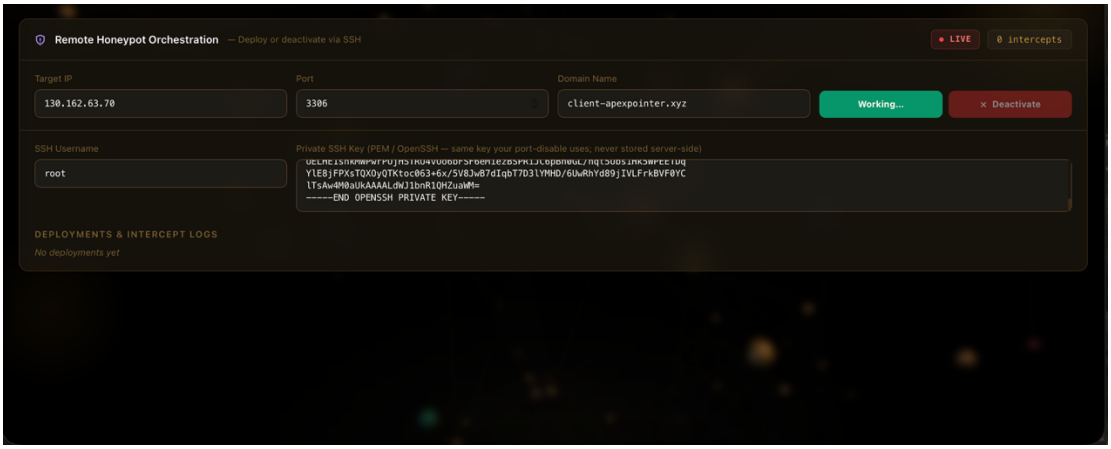
The adversary context and AI inference section outlines predictive threat telemetry, revealing the necessary threat actor skill range from Script Kiddie to APT, an estimated Time-to-Exploit (TTE) window of under 15 minutes, and the availability of a weaponized public Metasploit module.

To contextualize the business impact for stakeholders, a historical case study comparison references a real-world incident, the 2013 Yahoo Data Breach, explicitly highlighting scale metrics like 3 Billion leaked accounts and $470M USD in damage.

Finally, a tactical remediation directive provides engineers with immediate, actionable mitigation logic to secure the perimeter asset, instructing teams to bind MySQL to localhost, enforce strict source-IP whitelisting via iptables, and rotate all active credentials.

6# Honeypot features

Our **Remote Honeypot Orchestration** feature allows security teams to instantly deploy and manage strategic decoys across their external attack surface. By presenting simulated vulnerabilities—such as an open database on Port 3306—this module lures malicious actors and automated botnets away from real infrastructure. It intercepts probing activities in real time, capturing attacker fingerprints and IP threat intelligence without putting actual enterprise assets at risk



Core Architecture & Technical Highlights:

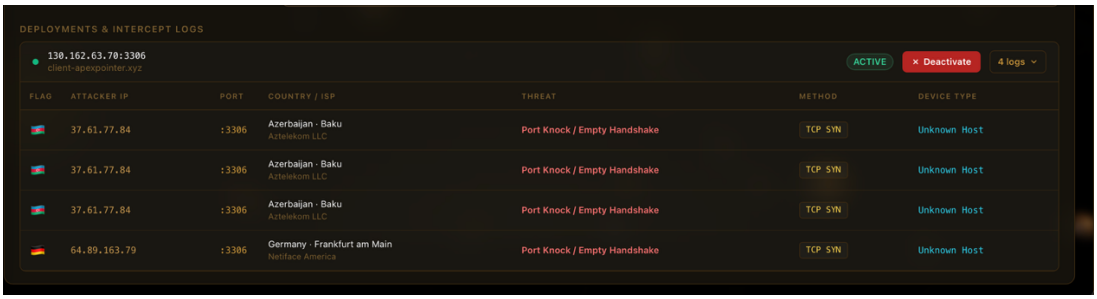
- **Infrastructure as Code (IaC) and Orchestration:** This is not just a script. Your platform automatically creates a Systemd Service (.service file) on the remote server via a command from the frontend, configures it, and binds it to the internal process manager using systemctl. In cybersecurity, this is called Automated Decoy Orchestration.
- **Reverse DNS (rDNS) and ISP Intel Lookup:** The appearance of names like Aztelekom LLC or client-apexpointer.xyz next to the IPs hitting the honeypot indicates an underlying integration of an Asynchronous DNS Resolver and MaxMind GeoIP / IP Intelligence API. The trap immediately enriches the incoming raw IP and converts it into threat intelligence (Threat Intel).
- **Low-Interaction Honeypot Architecture:** The system you built is a Low-Interaction honeypot. That means it does not run a real MySQL or Redis database inside; it simply responds in the language of those protocols (at the handshake level), wasting the attacker's time and resources without putting the system at full risk.

```
┌──(root㉿kali)-[~/cyber]
└─# nmap -p 445,1433,3306,3389,6379 130.162.63.70
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-25 12:54 -0400
Nmap scan report for 130.162.63.70
Host is up (0.032s latency).

PORT     STATE    SERVICE
445/tcp  open     microsoft-ds
1433/tcp open     ms-sql-s
3306/tcp open     mysql
3389/tcp filtered ms-wbt-server
6379/tcp open     redis

Nmap done: 1 IP address (1 host up) scanned in 2.02 seconds
```

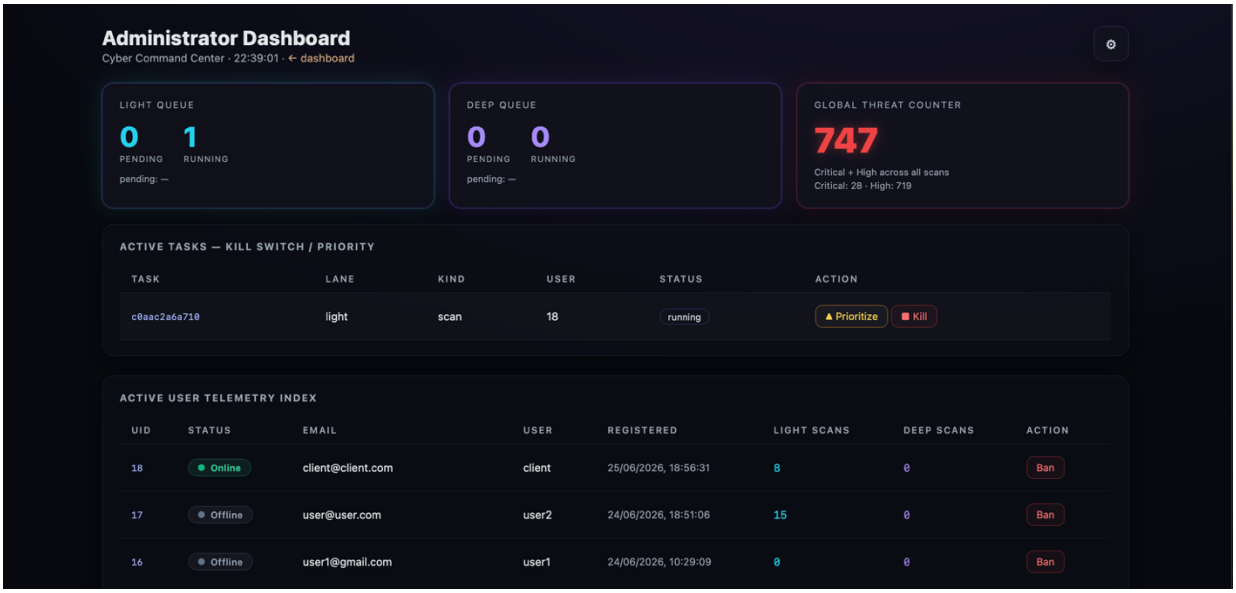
Network scan reveals that critical database and file-sharing ports (`445`, `1433`, `3306`, `6379`) are completely open to the internet. While this creates a high-risk attack surface, it provides the perfect environment to deploy our orchestration feature and trap incoming reconnaissance traffic.



Live Intercept Telemetry (Honeypot Logs) Once the MySQL decoy is activated on Port 3306, the platform instantly isolates adversarial behavior without risking actual data. The logs show real-time stealth scanning (`TCP SYN / Empty Handshake`) originating from both international scanning infrastructure (Germany) and local networks (Baku, Azerbaijan). This proves the feature successfully misdirects target discovery tools away from genuine assets while collecting actionable threat intelligence.

7# Admin dashboard

Since ApexPointer is designed as a scalable, multi-user platform, establishing a centralized administrative hub was essential; thus, the Administrator Dashboard was engineered to provide complete visibility, resource orchestration, and real-time telemetry over all platform users and active infrastructure scans. The interface highlights our centralized user navigation sidebar, where clicking on the "admin" user card seamlessly routes the authorized operator directly to the dedicated Admin Dashboard. Once redirected, the platform dynamically provisions executive features and access control configurations specific to administrative roles, including user ban mechanisms, threat monitoring thresholds, and granular system orchestration tools.



1. Real-Time Scan Queue Monitor (Light & Deep Queues)

- **The Feature:** Dynamic task management panels that provide real-time visibility into asynchronous external attack surface scans, categorized by computing intensity into **Light Queue** and **Deep Queue**.
- **The Tech Stack & Logic:** Built using distributed task queues (**Celery with Redis** or **BullMQ**). It displays the state of worker processes (`Pending` vs. `Running`) by subscribing to live event streams. This guarantees that background automated port scans and reconnaissance tasks do not block the main application thread.

2. Global Threat Counter

- **The Feature:** A high-impact security aggregation metric displaying a aggregated live count of exposed assets, critical vulnerabilities, and misconfigurations discovered across all infrastructure targets.
- **The Tech Stack & Logic:** Backed by an automated analytical pipeline that queries the primary database with an optimized query filtering vulnerabilities by severity tags

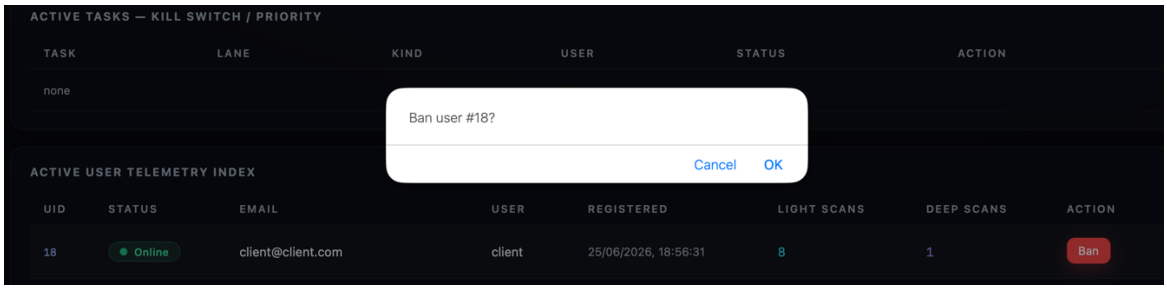
(`Critical: 28 - High: 719`). This metric dynamically transforms raw vulnerability data into a single, high-level risk score for senior security leadership.

3. Active Tasks Orchestration & Kill Switch / Priority

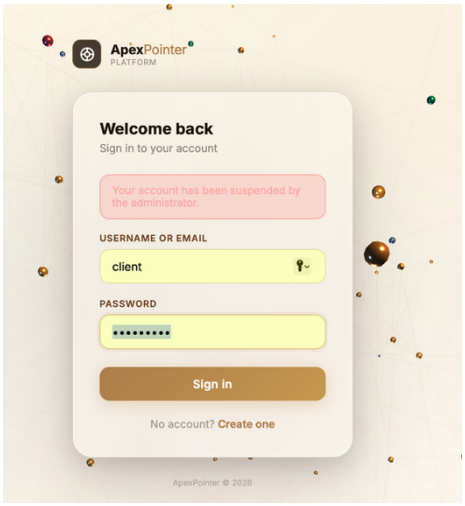
- **The Feature:** An interactive concurrency control room where administrators can dynamically triage running tasks.
- **The Tech Stack & Logic:** This panel leverages unique UUIDs (`c0aac2a6a710`) to track individual worker processes across the network lanes.
    - **Prioritize:** Interacts with the queue controller to re-index job priorities via distributed lock changes. As previously noted, our platform architecture is optimized to handle either 10 light scans or 2 deep scans concurrently. For example, if three users simultaneously initiate deep scans, two will execute immediately while the third is placed in the queue. If that pending scan is critical, this feature allows administrators to manually prioritize the user, bumping them to the front of the queue for immediate execution.
    - **Kill Switch:** Sends a forceful termination signal (SIGTERM / SIGKILL) over the system orchestration layer to instantly stop hanging or resource-heavy scans. This mechanism is vital for terminating malicious or compromised users whose aggressive scanning behavior threatens to degrade system performance or harm the infrastructure

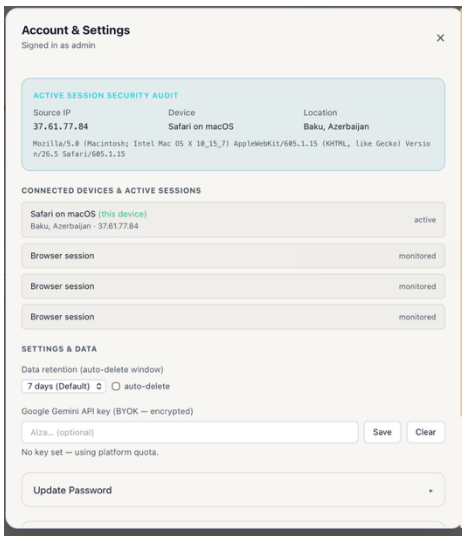
4. Active User Telemetry Index (Enhanced Real-Time CRM)

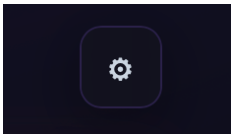
- **The Feature:** A centralized administrative console for user access telemetry, usage quotas (`Light Scans` vs. `Deep Scans`), and access management.
- **The Tech Stack & Logic:**
    - **Live Heartbeat Telemetry:** Leverages a sub-minute stateless polling or **WebSocket (Socket.io)** connection to seamlessly track the connection handshake. Users with a browser tab open dynamically toggle into a glowing green `Online` badge with an elegant heartbeat indicator.
    - **Granular Usage Tracking:** Executes real-time relational aggregation (`COUNT` queries grouped by `user_id` and filtered by `scan_type`) to transparently track metrics, ensuring clear auditable insight into platform ingestion.
    - **Hard-Termination Session Ban:** Empowered by an absolute access control middleware. Clicking **Ban**commits a state transition (`is_banned = true`) to the user metadata. Concurrently, the backend invalidates the active cryptographic session key or JWT (via a centralized session blacklist), immediately kicking the user to the auth screen with an explicit restriction payload.



Once you click OK, the banned user is automatically signed out upon refreshing the page. Furthermore, any subsequent login attempts using their credentials will display a '**Your account has been suspended by the administrator**.' message.







The layout presents the interface flow when clicking the settings gear icon on the Administrator Dashboard, which instantly launches the "Account & Settings" modal window. This control panel exposes several key user features, specifically an Active Session Security Audit (tracking IP, device, and location), an inventory of Connected Devices & Active Sessions, granular Settings & Data lifecycle management (including data retention windows), an encrypted Google Gemini API key (BYOK) configuration, a standard Update Password facility, and so on.

The end

In cybersecurity, the biggest enterprises have the massive budgets to protect themselves, but small businesses are often left to fight the storm alone. We engineered this entire suite on a minimal budget, but with a maximum mission: to prove that elite, automated defense shouldn't be a luxury—it should be accessible to everyone, in their own language. Our platform closes the gap between compromise and remediation because, at the end of the day, a secure digital perimeter shouldn't cost a fortune; it just requires the right engineering. Thank you.

https://github.com/EASMCISO/Project